

TrustLens AI — Sample Information Security Policy

Document ID: ISP-001 | Version: 1.0 | Classification: Internal

1. Purpose

This policy defines security controls for protecting organizational information, systems, applications, and data. It provides baseline requirements that can be audited and used as evidence of compliance.

2. Access Control

Access to systems must be granted according to least privilege and business need. User accounts must be uniquely assigned to individuals. Privileged access must be reviewed at least quarterly. Access must be removed within 24 hours after an employee or contractor leaves the organization.

3. Password and Authentication

Passwords must contain at least 12 characters and must not be reused across critical systems. Multi-factor authentication is required for administrative accounts and remote access to sensitive systems.

4. Data Protection

Sensitive and personal data must be encrypted during transmission and at rest using approved cryptographic mechanisms. Data must be retained only for the approved retention period and securely deleted when the retention period expires.

5. Incident Response

Security incidents must be reported immediately to the security team. Incidents must be recorded with timestamps, affected assets, severity, evidence, actions taken, and final resolution. High-severity incidents must be reviewed after closure.

6. Vendor Management

Third-party vendors that process organizational or personal data must undergo security assessment before onboarding. Contracts must define security responsibilities, data handling requirements, breach notification obligations, and termination procedures.

7. Backup and Recovery

Critical systems must be backed up according to documented recovery objectives. Backups must be protected from unauthorized access and periodically tested to verify that restoration is possible.

8. Compliance Evidence

Organizations must maintain trustworthy evidence showing that required controls are implemented. Evidence may include access reviews, configuration records, audit logs, incident records, vendor assessments, and backup test results.

9. Policy Review

This policy must be reviewed at least annually and whenever there is a significant change in technology, regulation, organizational structure, or security risk.